

Supplier & Vendor Compliance Policy

1. Purpose & Scope

This policy establishes governance standards for onboarding, monitoring, and managing third-party suppliers and vendors. It applies to all business units engaging external entities providing goods, services, technology, logistics, consulting, or outsourced operations. The objective is to ensure regulatory compliance, ethical conduct, operational resilience, and risk mitigation across the supply chain.



2. Vendor Risk Classification Framework



Risk Level	Criteria	Required Controls
Low	No PII access; limited operational impact	Basic contract & annual review
Medium	Indirect customer data access	Due diligence + compliance certification
High	Direct PII access or financial processing	Enhanced due diligence + quarterly audits
Critical	System-level integration or regulatory exposure	Full risk assessment + executive approval

3. Vendor Onboarding & Due Diligence

All vendors must undergo structured due diligence before contract execution. Screening includes financial stability checks, legal review, regulatory sanctions screening, and information security validation. Background verification applies where legally permitted.

Due Diligence Area	Verification Method
Corporate Registration	Official registry validation
Financial Stability	Audited financial statements review
Sanctions Screening	Global sanctions database check
Security Controls	ISO 27001 / SOC2 evidence review
Data Protection Compliance	GDPR / local regulation assessment

4. Ongoing Monitoring & Escalation

Risk Level	Monitoring Frequency
Low	Annual confirmation
Medium	Bi-annual review
High	Quarterly compliance audit
Critical	Continuous monitoring + executive review

Compliance violations are assessed based on severity and impact. Critical violations involving fraud, data breaches, or regulatory exposure must be escalated to Legal and Executive Risk Committees. Termination procedures shall follow documented contractual exit protocols.